

GSP Application	VAPT Report Response	Date: 20-08-2025
-----------------	----------------------	------------------

Summary

A Vulnerability Assessment and Penetration Testing (VAPT) exercise was conducted on our applications and infrastructure, focusing on <https://gsp.octagst.com/> and associated modules. The assessment identified **five issues**, all of which were carefully reviewed and addressed.

Key highlights:

Improper Error Handling: Fixed by implementing generic error messages instead of detailed exception traces.

Improper Input Validation: Report marked as false positive, as API workflows already validate payloads in an asynchronous two-stage process.

CSP Header Missing: A robust Content-Security-Policy header has been implemented across all responses.

Lucky 13 Attack Vulnerability: Mitigated by disabling weak CBC ciphers and ensuring TLS best practices.

Server Version Exposure: Custom server identifier header removed to prevent infrastructure detail disclosure.

As a result of these actions, **all reported issues have been remediated or confirmed as false positives**. The applications are now aligned with industry-recommended OWASP and TLS security guidelines, significantly reducing the attack surface and improving resilience against common web security threats.

Issue-1: Improper Error Handling (Medium)

Description:

Improper handling of errors can introduce a variety of security problems for a web site. The most common problem is when detailed internal error messages such as stack traces, database dumps, and error codes are displayed to the user (hacker).

Reason (Root Cause):

When the application received an invalid JSON request payload, it responded with a detailed parsing error (HTTP 400 Bad Request), including internal deserialization exception details.

Action Taken (Fix Implemented):

- All exceptions are now caught at the application layer.
- Instead of returning internal stack traces, the application returns a **generic error message**.
- The response now follows this format:
 - **HTTP Status Code:** 400 Bad Request
 - **Response Body:** {"status":400,"message":"Invalid request payload"}

Result:

- Internal exception details are no longer exposed.
- End users only see a generic message, preventing information disclosure.
- Security posture improved in line with OWASP recommendations.

Conclusion:

Issue resolved —Error handling done as per recommended.

Issue-2: Improper Input Validation (Medium)

Description:

Improper input validation occurs when an application fails to properly check or sanitize user input, allowing malicious data to pass through and potentially exploit the system.

Action Required:

No action required: **False positive**

Actual Design (Asynchronous Two-Stage Validation)

Return Data Saving is intentionally **asynchronous** to handle very large transaction payloads:

- **Stage-1 (Ingest & Acknowledge):**
 - Endpoint receives the payload and **performs minimal gate checks** (e.g., Content-Type, JSON well-formedness,).
 - Triggers a **background validation job**, and immediately returns a **Reference ID** for status polling.
 - **No business action** is taken on the data at this point.
- **Stage-2 (Secure Background Validation):**
 - Background worker **decrypts** the payload and verifies **HMAC** (integrity & authenticity).
 - If HMAC fails → payload is **rejected**.
 - If HMAC passes → **every transaction record** is validated (type/length/format/domain rules/cross-field rules).
 - Processing time can be up to ~20 minutes depending on payload size; results are retrieved via **Get Return Status**.
- **Status API (Polling):**
 - Clients call **Get Return Status** with the reference ID to obtain validation state and any error details.
 - Only **validated** data moves forward to persistence and downstream workflows.

Key point:

The system **does not use or commit unvalidated data**. Validation is comprehensive, just **deferred** to a secure background pipeline by design.

Why the Finding Is a False Positive

- **Validation exists and is enforced before use:** All records are validated **prior** to any business effect or persistence. This satisfies **CWE-20 (Improper Input Validation)** requirements.
- **Integrity is verified first: HMAC verification** prevents tampering; malformed or forged payloads are rejected before record-level validation.

- **Asynchronous ≠ missing validation:** The validator runs **out-of-band** for scalability, not skipped. No action is performed until validation succeeds.
- **Controlled ingestion:** Stage-1 applies **syntactic checks and size limits**; Stage-2 enforces **semantic and business validations**.

Evidence & Re-Test Guidance (for VAPT)

Save GSTR-1 Payload (data: "<h1>Hello</h1>")

PUT https://gsp.octagst.com/gst/taxpayerapi/v4.1/returns/gstr1

200

Network

Show

Request Headers

gstin: "27AXTPJ8438P1ZB"
state-cd: "27"
ip-usr: "192.168.29.160"
auth-token: "d9717704e4df40b5b6457f99fcabda82"
ret_period: "022025"
userrole: "GSTR1"
rtn_tpy: "GSTR1"
api_version: "4.1"
txn: "TXN834"
username: "MH_NT4.2809"
Content-Type: "application/json"
Authorization: "Basic YTYzODgxNDI0MTM5NTc5OTQ3ODo2Mng4IVAyUz8Bd25TTVV0VUhJTQ=="
User-Agent: "PostmanRuntime/7.45.0"
Accept: "*/*"
Cache-Control: "no-cache"
Postman-Token: "00a47ae2-91f6-48fb-b01b-6d884fe75429"
Host: "gsp.octagst.com"
Accept-Encoding: "gzip, deflate, br"
Connection: "keep-alive"
Content-Length: "117"

Request Body

```
{
  "action": "RETSAVE",
  "data": "<h1>Hello</h1>",
  "hmac": "F7iyJTwGfUPLqY9bFfpXa0M/fWvialdogj8EoybCaR0="
}
```

Response Headers

content-type: "application/json; charset=UTF-8"
date: "Wed, 20 Aug 2025 06:36:02 GMT"
transfer-encoding: "chunked"
strict-transport-security: "max-age=31536000"
vary: "Accept-Encoding"
content-encoding: "gzip"

Response Body

```
{
  "status_cd": "1",
  "data": "i8cxBMcu5kFlMGXkm6H1TnP7VtLPw20u8EekW/BNaX8k1P2wLj19+s5PehEvSwCar9bFmAGJKka8z1qZk8+vxyGypetI43A1n67EcP/C3Mo=",
  "rek": "51e4ngFH1mAfFB1B/vCfNVFQKrf0EZ+aUbb/kxHXVsWEnt0icfhL5VVnHQj78jYc",
  "hmac": "1utvYupSuLFkm21ERQ8JGNLk0g4suRObKEF1ZwxKBA="
}
```

Decrypt Payload and Get Reference Id

POST https://gsp.octagst.com/gst/tool/decryptgstpayload

Network

Request Headers

Content-Type: "application/json"
Authorization: "Basic YTYzODgxNDI0MTM5NTc5OTQ3ODo2Mng4IVAyUz8Bd25TTVV0VUhJTQ=="
User-Agent: "PostmanRuntime/7.45.0"
Accept: "*/*"
Cache-Control: "no-cache"
Postman-Token: "23ad5048-162c-4991-9e6b-2f55189ca881"
Host: "gsp.octagst.com"
Accept-Encoding: "gzip, deflate, br"
Connection: "keep-alive"
Content-Length: "270"

Request Body

```
{
  "sek": "IeAbD8BE+1Hp9C0sEBePFBUSxWwbbIqF4BReImUTB4=",
  "encRek": "51e4ngFH1mAfFB1B/vCfNVFQKrf0EZ+aUbb/kxHXVsWEnt0icfhL5VVnHQj78jYc",
  "encData": "i8cxBMcu5kFlMGXkm6H1TnP7VtLPw20u8EekW/BNaX8k1P2wLj19+s5PehEvSwCar9bFmAGJKka8z1qZk8+vxyGypetI43A1n67EcP/C3Mo="
}
```

Response Headers

content-type: "application/json; charset=utf-8"
date: "Wed, 20 Aug 2025 06:37:55 GMT"
transfer-encoding: "chunked"
strict-transport-security: "max-age=31536000"
vary: "Accept-Encoding"
content-encoding: "gzip"

Response Body

```
{
  "rek": "N6sC1NgwN7cJkLk66GoIUZgJIW2CjoakEDmXPImEMuA=",
  "data": "{\n  \"reference_id\": \"2dd10cc0-49ce-47c8-9d64-991a32394166\"\n}"
}
```

GST API Data

```
{
  "reference_id": "2dd10cc0-49ce-47c8-9d64-991a32394166"
}
```

Blowbits Solutions LLP	OwnZap-1.8.1-2025	Page 4 of 8
------------------------	-------------------	-------------

Use Reference Id to get status by calling Return Status API

GET https://gsp.octagst.com/gst/taxpayerapi/v1.1/returns?action=RETSTATUS&gstin=27AXTPJ8438P1Z&ret_period=022025&ref_id=2dd10cc0-49ce-47c8-9d64-991a32394166

200

Network

Request Headers

gstin: "27AXTPJ8438P1Z"
state-cd: "27"
ip-usr: "192.168.29.160"
auth-token: "d9717704e4df40b5b6457f99fcabda82"
ret_period: "022025"
username: "MH_NT4.2809"
txn: "TXN774"
Authorization: "Basic YTYzODgxNDI0MTM5NTc5OTQ3ODo2Mng4IVAYUzBBd25TTVVdVUhJTQ=="
User-Agent: "PostmanRuntime/7.45.0"
Accept: "*/*"
Cache-Control: "no-cache"
Postman-Token: "813103a5-ca24-48f3-8dc8-483a8243701d"
Host: "gsp.octagst.com"
Accept-Encoding: "gzip, deflate, br"
Connection: "keep-alive"

Response Headers

content-type: "application/json; charset=UTF-8"
date: "Wed, 20 Aug 2025 06:39:20 GMT"
transfer-encoding: "chunked"
strict-transport-security: "max-age=31536000"
vary: "Accept-Encoding"
content-encoding: "gzip"

Response Body

{ "status_cd": "1", "data": "RvqTMB9yggKPCprK015xOMs5864IAk3qxNMfUrRwHByPvQ3srj1A0mxBSv9/uj05GKCLXNHm4GyzPn+IvxwvYH0t0T7/9Wf5Ay1zm20GyGE17jAQ9St7yTzRjPLXZ0mf03MnFm1K0oBvppvm9mVg1k4Za62wahMMwXv+PuqaT1c9z5GK201NzhLAJhHZ+R12u6A76INm9uZHKJzWiH0qribq8yfwHQrgbQkims7CyS/c=", "reK": "cJG1hDvWvSP6DZ1X01a5319dmAqx2tz/kUEG67n1b8mENT0icfhl5VVnHQj78jYc", "hmac": "3D+C0+URyu2xj+LkavVKYSjK9wMJOR9coQNBvDehzE0=" }

Decrypt Payload and Check Response:

Payload will show error

POST https://gsp.octagst.com/gst/tool/decryptgstpayload

Network

Request Headers

Content-Type: "application/json"
Authorization: "Basic YTYzODgxNDI0MTM5NTc5OTQ3ODo2Mng4IVAYUzBBd25TTVVdVUhJTQ=="
User-Agent: "PostmanRuntime/7.45.0"
Accept: "*/*"
Cache-Control: "no-cache"
Postman-Token: "a03cb81c-68b3-447a-a736-78c8cb0e02be"
Host: "gsp.octagst.com"
Accept-Encoding: "gzip, deflate, br"
Connection: "keep-alive"
Content-Length: "398"

Request Body

Response Headers

content-type: "application/json; charset=utf-8"
date: "Wed, 20 Aug 2025 06:40:07 GMT"
transfer-encoding: "chunked"
strict-transport-security: "max-age=31536000"
vary: "Accept-Encoding"
content-encoding: "gzip"

Response Body

"GST API Data" {"form_typ": "R1", "status_cd": "ER", "action": "SAVE", "error_report": {"error_msg": "Corrupted Data or File", "error_cd": "RET191103"}}

Conclusion

- The system **does validate all inputs** comprehensively **before use**; it simply performs full validation **asynchronously** for scalability.
- Therefore, the reported **“Improper Input Validation”** is a **false positive**.
- We request the finding be **closed** after re-testing with the above steps.

Issue-3: CSP Header Missing (Low)

Description:

Missing the Content-Security-Policy (CSP) header can leave a web application vulnerable to various types of attacks, particularly cross-site scripting (XSS) and data injection attacks.

Action Taken

- A CSP header has been implemented and added to application responses.
- The CSP restricts sources of JavaScript, images, stylesheets, and other resources to the application's own domain.
- Only trusted domains are allowed, preventing the loading of malicious external resources.
- While 'unsafe-inline' and 'unsafe-eval' are temporarily included for framework compatibility, the CSP still significantly reduces the XSS attack surface by blocking third-party script injection.

CSP applied:

Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-eval' 'unsafe-inline'; img-src 'self' data:; style-src 'self' 'unsafe-inline'; connect-src 'self'

Result

- The CSP header is now present in all responses.
- Browser-enforced policies ensure that only trusted same-origin resources are executed.
- This provides protection against script injection attacks and aligns with OWASP recommended security controls.

Conclusion:

Issue resolved — CSP header implemented and active. Future releases will focus on progressively removing 'unsafe-inline' and 'unsafe-eval' once framework and library dependencies are updated.

Issue-4: Server is Vulnerable to Lucky 13 Attack (Low)

Description:

Lucky 13 vulnerability is a timing side-channel flaw in the TLS protocol affecting Cipher Block Chaining (CBC) mode ciphers. In this guide, we'll walk through the necessary steps to mitigate this vulnerability and reinforce the security of your network communications.

Action Taken

- Our TLS configuration has been **hardened** to disable the use of weak CBC ciphers.
- TLS minimum version is enforced as **TLS 1.2** with strong cipher suites only.
- Verification with **nmap ssl-enum-ciphers** confirms that only AEAD ciphers (AES-GCM, CHACHA20-POLY1305) are negotiated. CBC ciphers are no longer accepted.

Result

- **CBC suites removed**, thus eliminating exposure to Lucky 13.
- Current supported ciphers are **TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, and TLS_CHACHA20_POLY1305_SHA256**.
- No practical risk of Lucky 13 exists on the server after this configuration update.

```
% nmap --script ssl-enum-ciphers -p 443 gsp.octagst.com

Starting Nmap 7.97 ( https://nmap.org ) at 2025-08-19 21:09 +0530
Nmap scan report for gsp.octagst.com (13.234.189.188)
Host is up (0.022s latency).
rDNS record for 13.234.189.188: ec2-13-234-189-188.ap-south-1.compute.amazonaws.com

PORT      STATE SERVICE
443/tcp   open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|     compressors:
|       NULL
|     cipher preference: client
|   TLSv1.3:
|     ciphers:
|       TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|       TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|     cipher preference: client
|_  least strength: A

Nmap done: 1 IP address (1 host up) scanned in 1.98 seconds
```

Conclusion: Issue resolved — **Server is not vulnerable to Lucky 13.**

Issue-5: Server Version Exposure (Low)

Description:

Exposing server version information through HTTP headers, error messages, or metadata can reveal details about the technologies used, making the system vulnerable.

Action Taken

- The reported header **x-server: ProtonServer1** was **not a version string**, but an internal tag identifying the server instance that processed the request.
- While this header did not expose any software version, it could reveal internal infrastructure details.
- To avoid unnecessary information disclosure, the header has been **removed** from all server responses.

Result

- **No server version or infrastructure identifiers** are exposed in response headers.
- The application now returns **generic, minimal headers** only, in compliance with best practices for security hardening.

Conclusion: Issue resolved — **Server version exposure eliminated.**